

Lakeside Family Clinic

HIPAA Security Assessment & Executive Risk Summary

Prepared by: Jacob Bryer

Fictional engagement — created for portfolio purposes only. Lakeside Family Clinic is a fictional company. No real patients, staff, or data are represented.

1. Executive Summary

Lakeside Family Clinic handles patient records every day across systems that store and process electronic protected health information (ePHI). This assessment looked at the security practices around those systems — not at clinical care quality or billing accuracy, but at the controls that protect patient data from unauthorized access, loss, or exposure.

The clinic's security basics are in place in some areas but haven't been applied consistently. The highest-priority issues right now are accounts that can reach the EHR and patient files without multi-factor authentication, shared login credentials on clinical workstations, backups that have never been tested, and no written plan for responding to a security incident. Any one of these creates real exposure — not just a compliance checkbox, but the kind of disruption that could affect patient care and be expensive to clean up.

This document explains each risk, what's behind it, and what to do about it in a realistic sequence. For the likelihood scores, impact scores, and estimated financial exposure ranges behind each risk, see the Quantified-Risk-Register.xlsx.

2. Assessment Scope and Methodology

Scope

This assessment covers:

- Access controls for systems containing patient information
- User account provisioning and deprovisioning
- Multi-factor authentication
- Workstation security
- Email and phishing risk
- Data backup and recovery
- Audit logging and monitoring
- Security awareness training

- Incident response readiness
- Vendor and third-party risk
- Policies and procedures related to patient data protection

Out of scope: Clinical care quality, billing accuracy, legal interpretation of HIPAA, and physical facility safety.

Assumptions

- Findings are based on the fictional clinic environment and stakeholder representations described above, not on technical testing.
- No vulnerability scanning or penetration testing was performed as part of this scenario.
- Risk scoring reflects a point-in-time snapshot and assumes no changes were made during the engagement.

Methodology

1. Review the fictional clinic environment and assumptions
2. Identify systems and processes that store, process, or transmit ePHI
3. Evaluate current safeguards against HIPAA Security Rule concepts
4. Document security gaps and the business risk behind each one
5. Score each risk by likelihood, impact, and estimated financial exposure
6. Recommend remediation steps based on risk priority

3. Key Risk Themes & Business Impact

The findings below cover the most significant gaps affecting the confidentiality, integrity, and availability of ePHI at Lakeside Family Clinic. Each risk is tied to a HIPAA Security Rule reference and corresponds to a scored entry in the Quantified-Risk-Register.xlsx.

A. Identity and Access Governance

● **H-01: MFA Not Consistently Enforced — §164.312(a)(1)**

Staff accounts for email, cloud file storage, and the EHR don't all require multi-factor authentication. A single stolen or guessed password could give an attacker direct access to patient records. MFA is already available in the platforms the clinic uses — it just hasn't been turned on for everyone.

This matters because credential theft and phishing-driven account takeovers are among the most common starting points for healthcare breaches. MFA blocks the vast majority of those attempts.

● **H-02: Shared Workstation Logins — §164.312(a)(2)(iii)**

Nurses and front-desk staff share generic credentials on clinical workstations. The practical problem: if a patient record is accessed or modified incorrectly, there's no way to trace it back to a specific person. HIPAA requires that individual actions on systems containing ePHI be attributable — shared credentials make that impossible.

● **H-03: Inconsistent User Offboarding — §164.308(a)(3)(ii)(C)**

When a staff member leaves, their access to billing systems and email isn't being removed on any defined timeline. There's no formal agreement between HR and IT on how quickly this has to happen, which means former employees could still have active credentials to systems containing patient data.

B. Resilience and Incident Readiness

● **H-04: Audit Logs Exist But Nobody Reviews Them — §164.312(b)**

The EHR generates security logs — record exports, failed login attempts, access events — but no one looks at them. Suspicious activity like a bulk record export or a pattern of failed logins would go completely unnoticed until something more obvious happened.

● **H-05: Backups Run But Have Never Been Tested — §164.308(a)(7)(ii)(B)**

Cloud backups run nightly and report success. But the clinic has never verified that those backups can actually restore the system in a real scenario. Untested backups fail at a surprisingly high rate — and discovering that during a ransomware response is the worst possible time to find out.

● **H-06: No Incident Response Plan — §164.308(a)(6)(ii)**

If something happened — ransomware, a phishing-driven breach, or an email account compromise — the clinic's response would be improvised. There's no written plan covering who does what, who gets notified, and by when. HIPAA has specific breach notification requirements with hard timelines; without a plan, meeting those deadlines under pressure is very difficult.

C. Oversight and Third-Party Risk

● *H-07: No Consistent Vendor Risk Process — §164.308(b)(1)*

Third-party services that touch patient data — cloud platforms, billing tools, scheduling software — are selected based on features and cost, not security. Business Associate Agreements (BAAs) aren't tracked centrally, which creates compliance gaps and the practical risk that a vendor-side breach could expose patient data without the clinic knowing until after the fact.

● *H-08: Security Training Only Happens at Onboarding — §164.308(a)(5)(i)*

Staff get a brief security orientation when they're hired and not much after that. Phishing attempts and social engineering tactics have gotten more sophisticated over time; a one-time onboarding mention doesn't give staff the awareness they need to recognize and avoid today's threats.

D. Additional Findings

● *H-09: ePHI Sometimes Shared Outside Secure Channels — §164.312(e)(1)*

Some clinical documentation gets sent through regular email or via public sharing links from cloud storage. Neither method is inherently secure or auditable, and a misconfigured share link could expose patient data to anyone who has the URL.

● *H-10: Core Security Policies Are Outdated — §164.316*

The clinic has a general code-of-conduct document that's several years old and hasn't been updated to reflect current data handling expectations, password standards, or incident reporting steps. Documented policies both support compliance and give staff clear guidance on what they're expected to do.

4. Prioritized Remediation Roadmap

The recommended approach prioritizes technical controls that directly reduce the most impactful risks first, before moving to documentation and longer-term program work. This isn't about doing everything at once — it's about doing the right things in the right order.

Phase 1: Do These First (0–30 Days)

Turn on MFA for every staff account (H-01). Email, EHR, cloud storage — no exceptions. MFA is already available in the systems the clinic uses. This is the single most impactful step and costs essentially nothing to implement.

Create a formal offboarding agreement between HR and IT (H-03). Set a hard rule: all access gets revoked within 24 hours of someone leaving. Put it in writing so both sides know what's expected.

Phase 2: Fix the Workflow Issues (31–90 Days)

Create individual logins for each staff member on clinical workstations (H-02). If workflow speed is a real concern, badge tap-in systems work well in clinical settings and are worth looking into.

Test an actual restore from the cloud backups (H-05). Document how long it takes and what works. If the restore fails or takes significantly longer than expected, that's important to know now, not during a ransomware response.

Write a basic incident response plan (H-06). It doesn't need to be long — the key pieces are: who's responsible for what, who gets contacted and in what order, and specific steps for the two most likely scenarios: ransomware and a compromised email account.

Set up a weekly EHR audit log summary (H-04). Configure the system to flag high-volume record exports, repeated failed logins, and unusual access patterns. Someone needs to actually look at those reports on a regular schedule.

Phase 3: Build the Sustained Practices (91–180 Days)

Start a recurring security training and phishing simulation program (H-08). Monthly short reminders and quarterly simulated phishing tests are realistic for a 25-person clinic and make a real difference in how staff recognize and respond to threats.

Build a central Business Associate Agreement registry (H-07). Track which vendors have signed BAAs, when they expire, and whether the security terms have been reviewed. Add a basic security review step to new vendor onboarding.

Update core security policies (H-10). Draft a short set of foundational policies covering data handling, password expectations, and incident reporting. Get them signed by leadership and distributed to staff.

Lock down external sharing settings (H-09). Configure email and cloud storage so that ePHI can't be sent unencrypted or shared via open public links. This can often be done through existing Microsoft 365 or Google Workspace settings.

Disclaimer

Lakeside Family Clinic is a fictional company created for portfolio purposes. All findings, risks, and recommendations in this folder are fictional and don't represent any real company or client. This isn't legal advice and isn't a formal HIPAA compliance determination.